

ПРАКТИЧЕСКАЯ РАБОТА № 11

Тема: DDoS (Distributed Denial of Service) - основные особенности их организации и защиты от них.

Программное обеспечение:

1. Программное обеспечение, необходимое для проведения различных DDOS – атак (находится в папке PRZ_11_distr_DDOS)
<https://drive.google.com/drive/folders/143Qs0Gxg4wWRFledAh3CjMjuOe7iTcxr?usp=sharing>

Вопросы для обсуждения:

1. Принцип работы каждой из сетевых атак типа «отказ в обслуживании»?
2. Какие аномалии в сетевом трафике и ресурсах сервера вы заметили в каждой атаке?
3. Что является признаком конкретной атаки?
4. В чем отличие DDoS от DoS?
5. Что такое UDP-флуд?
6. Как защититься от различных атак DoS/DDoS?
7. Что такое SYN-флуд? Укажите решение защиты от SYN-флуда с помощью iptables.
8. Как определить, что осуществляется атака SYN-флуд?
9. Как осуществить защиту от HTTP-флуда?
10. Как работают атаки типа SlowLoris?
11. Как совершить DDoS-атаку на почтовый сервер и в дальнейшем реализовать его защиту?
12. Как работают атаки типа SSL? Как определить, что осуществляется атака?
13. Перечислите Amplification атаки с коэффициентами их усиления.
14. Опишите теоретически возможность расследования DoS/DDoS атак, установление личности атакующего, определение источников атак.

Цель: получить теоретические и практические навыки о принципах осуществления DDoS атак и защиты от них.

Основные теоретические сведения

1. DoS/DDoS

DoS (от англ. Denial of Service — отказ в обслуживании) — хакерская атака на вычислительную систему с целью довести её до отказа, то есть создание таких условий, при которых легальные пользователи системы не могут получить доступ к предоставляемым системным ресурсам (серверам), либо этот доступ затруднён. Отказ «вражеской» системы может быть и шагом к овладению системой (если в нештатной ситуации ПО выдаёт какую-либо критическую информацию — например, версию, часть программного кода и т.д.). Но чаще это мера экономического давления: простой службы, приносящей доход, счета от провайдера и меры по уходу от атаки ощутимо бьют «цель» по карману. В настоящее время DoS и DDoS-атаки наиболее популярны, так как позволяют довести до отказа практически любую систему, не оставляя юридически значимых улик.

Если атака выполняется одновременно с большого числа компьютеров, говорят о DDoS-атаке (от англ. Distributed Denial of Service, распределённая атака типа «отказ в обслуживании»).

Для обнаружения распределённых сетевых атак типа «отказ в обслуживании» и защите от них необходимо классифицировать их и знать принципы их работы.

В данной работе критерием для классификации рассмотрим объект, на который нацелена атака. В таком случае, получается четыре основных класса атак, соответствующих уровням модели ISO OSI.

Канальный уровень (L2) — атаки направлены на исчерпание ёмкости сетевого канала. В следствие этого лишается доступ сервера к внешней сети. Для реализации используются объёмные потоки трафика. На данным момент измеряются в Гб/с. Во время данной атаки обрабатывать трафик необходимо

на стороне провайдера, дата-центра. С помощью BGP Flow Spec фильтруется часть атак по сигнатурам пакета. Amplification атаки отсекаются по порту.

Сетевой уровень (L3) — атаки направлены на нарушение работы элементов сетевой инфраструктуры. Необходим ручной анализ сетевой инфраструктуры. Если своей автономной системы нет, то борьба с атаками данного класса ведется провайдером или дата-центром. Желательно сотрудничество с ними.

Транспортный уровень (L4) — атаки направлены на эксплуатацию слабых мест TCP-стека. В TCP протоколе используется таблица открытых соединений. Атаки именно на неё составляют этот класс. Необходим постоянный анализ поведения TCP-стека, TCP-клиентов, TCP-пакетов. Эвристический анализ.

Прикладной уровень (L7) — атаки направлены на нарушение работы Web-приложения. Атаки этого класса характеризуются большим разнообразием. Исчерпывают ресурсы сервера. Необходим поведенческий и корреляционный анализ, мониторинг ресурсов сервера. Необходима оптимальная настройка сервера под решаемые им задачи. Полностью автоматизировать борьбу с данным классом атак почти невозможно.

2. Медленная атака. SlowLoris

Уровень атаки: транспортный уровень (L4).

Описание и принцип работы:

Атака Slowloris устанавливает много открытых соединений на сервере с помощью постоянной отправки незавершенных HTTP-запросов. В определенные моменты времени Slowloris отправляет следующие HTTP заголовки для каждого запроса, но не завершает соединение. Если запросы посылаются с оптимальной периодичностью, сервер начинает ожидать завершения открытых соединений. В данном случае ресурсы сервера остаются относительно свободными, но сам сервер перестаёт обслуживать новые подключения.

Дело в том, что веб-серверы Apache 1.x, Apache 2.x, dhttpd, GoAhead WebServer и Squid поддерживают ограниченное число одновременно открытых подключений. Но Slowloris не представляет угрозы для серверов IIS, lighttpd, NGINX. Они имеют эффективные механизмы распределения нагрузки и используют worker pool — «пулы рабочих потоков», которые позволяют удерживать любое количество открытых соединений при наличии свободных ресурсов.

3. Медленная атака. Slow HTTP POST/GET

Уровень атаки: транспортный уровень (L4).

Описание и принцип работы:

Атака основана на уязвимости в протоколе HTTP. Slow HTTP POST атака отправляет POST заголовок с полем «Content-Length». Веб-сервер понимает, какой объём данных он должен получить. После этого с очень низкой скоростью передаётся тело POST сообщения. Это позволяет задействовать ресурсы сервера длительное время, и в последствии помешать обработке других запросов. Атака опасна для веб-серверов Microsoft IIS и Apache, и NGINX со стандартными настройками в рамках протоколов HTTP, HTTPS, подключений SSL, VPN. Также атака может быть настроена для работы с SMTP и DNS-серверами.

Данный тип атаки на отказ в обслуживании, можно организовать через проху. Трафик данной атаки схож с легитимным трафиком.

4. Медленная атака. Sockstress

Уровень атаки: транспортный уровень (L4).

Описание и принцип работы:

Атака заключается в следующем. Если на веб-сервере есть объект, размер которого больше send buffer, выделенного ядром для соединения. То можно заставить ядро не принимать данные, а сервер будет пробовать отправить кусок данных, занимая стек соединений, ресурсы процессора и

память. При большом количество подобных соединений TCP-стек заполнится и не будет открывать новые соединения.

Примеры:

Отправить в пакете размер окна равный нулю, то есть нет места для получения данных. Скрипт Sockstress отправляет такие пакеты и считает время, когда их отправлять, чтобы не загрузить persist timer.

Создать сокет с малым объёмом receive buffer на клиенте. Отправлять HTTP-запрос на объект сайта больший по размеру, чем буфер. И периодически считываем пару байт из receive buffer. Сервер будет пытаться отправлять данные и занимать ресурсы.

5. Атака произвольными пакетами. HTTP-Flood

Уровень атаки: канальный уровень (L2), прикладной уровень (L7).

Описание и принцип работы:

В основе этой атаки лежит механизм отправления максимального числа HTTP запросов на 80-й порт веб-сервера. Целью атаки может быть корень сервера или ресурсоёмкий элемент. В результате данной атаки возможно прекращение предоставления услуг по HTTP, и затруднен доступ легитимных пользователей к сайту. Распознать атаку можно с помощью выявления быстрого роста количества запросов к некоторым элементам веб-сервера и логов сервера.

6. Атака произвольными пакетами. UDP-Flood

Уровень атаки: канальный уровень (L2), прикладной уровень (L7).

Описание и принцип работы:

UDP flood атака основана на отправке большого количества UDP-пакетов на некоторые порты сервера. Он должен определить приложение для каждого полученного пакета, удостоверится в его неактивности и отправить в ответ ICMP-сообщение «недоступен». В итоге вырастут затрачиваемые ресурсы атакуемого сервера, и полоса пропускания заполнится UDP-пакетами.

В UDP протоколе нет механизма проверки отправителя пакетов, тем самым злоумышленник может подменить IP-адреса и обеспечить анонимность.

7. Атака произвольными пакетами. SYN-Flood

Уровень атаки: канальный уровень (L2), транспортный уровень (L4).

Описание и принцип работы:

SYN Flood атака использует механизм рукопожатия в протоколе TCP. Работает следующим образом. Посылается пакет с флагом SYN на атакуемый сервер. Он вынужден отправить в ответ пакеты с флагами SYN+ACK. Злоумышленник игнорирует SYN+ACK пакеты сервера и не высылает в ответ пакет ACK. Либо подделывает IP-адрес SYN пакета, чтобы ответный SYN+ACK отправлялся на некорректный адрес. Цель данной атаки — заполнение TCP стека множеством полуконечных соединений, в следствие чего сервер перестают устанавливать соединения с новыми клиентами. Запросы на соединение, полученные сервером, хранятся в стеке с определенным размером, который зависит от операционной системы. Они находятся в стеке, пока сервер не получит информацию об установленном соединении от клиента.

8. Атака произвольными пакетами. ICMP-Flood

Уровень атаки: канальный уровень (L2).

Описание и принцип работы:

Данный тип флуда направлен на сетевое оборудование. Принцип данной атаки заключается в том, что ICMP-пакет при небольшом размере самого запроса требует от устройств значительно большего объёма работы. То есть, при отправлении сравнительно небольшого объёма ICMP запросов возникает перегрузка сетевого оборудования, и значительная часть легитимных запросов теряется. Злоумышленник, меняет IP-адрес источника, отправляет ICMP Echo Request пакет к определённым компьютерам, входящим в бот-нет. Они

отвечают ICMP Echo Reply пакетом, посылая его на изменённый IP-адрес. Для увеличения мощности атаки используют локальные сети (LAN) с включенной опцией направленной широковещательной рассылки (directed broadcast).

9. Атака с помощью SSL

Уровень атаки: прикладной уровень (L7).

Описание и принцип работы:

Secure Sockets Layer (SSL) — это протокол безопасности для защиты целостности сети связи и передачи данных. SSL может зашифровать подключение к сети на транспортном уровне. Процессы шифрования протокола SSL, расшифровки и обмена ключами потребляют огромное количество системных ресурсов. Существует два типа атак основанных на протоколе SSL.

Первый тип эксплуатирует механизм рукопожатия, который истощает ресурсы атакуемого сервера. Злоумышленник посылает некорректные SSL данные на сервер, на обработку которых затрачивается большое количество вычислительной мощности.

Второй тип использует функцию повторного подтверждения соединения — SSL Renegotiation.

Установка безопасного соединения и повторное подтверждение SSL затрачивают в разы больше вычислительной мощности на сервере, чем на стороне клиента. Благодаря этому возможно осуществление атаки и истощение ресурсов атакуемого сервера. Как правило, HTTPS расшифровывается глубоко внутри организационной сети, где серверы и модули более уязвимы к вредоносному трафику. Также злоумышленники используют этот протокол для обхода механизмов безопасности. Таким образом, возможно туннелирование других атак.

10. Атака почтового сервера. SMTP-Flood

Уровень атаки: прикладной уровень (L7).

Описание и принцип работы:

В атаках этого типа злоумышленник пытается установить соединение с почтовым сервером и отправляет произвольные письма на сгенерированные случайным образом адреса, либо бездействует до истечения тайм-аута, удерживая соединение открытым. Каждое SMTP соединение утилизирует часть ресурсов сервера, тем самым атакующий пытается вызвать отказ в обслуживании.

Технология заключается в том, что когда мы пишем e-mail получателя несуществующий, то SMTP server оповещает нас с помощью e-mail(отправителя), что письмо не дойдёт. Мы посылаем на SMTP server очень много запросов (пишем письма) и указываем все e-mail не валидные, а отправителя (объект атаки). И к нему будут приходить уведомления, что письмо не дошло. С нескольких SMTP server будет отправляться трафик на объект атаки.

11.Некорректные пакеты/фрагменты. UDP fragment flood

Уровень атаки: прикладной уровень (L7).

Описание и принцип работы:

Данный тип атаки основан на отправке UDP датаграмм, которые случайным образом ссылаются на датаграммы отсутствующие в потоке. Это приводит к увеличению потребления памяти на атакуемом сервере. При атаке UDP Fragment Flood, злоумышленники посылают UDP пакеты большого размера, для истощения пропускной способности канала.

12.Некорректные IP-фрагменты

Уровень атаки: прикладной уровень (L7).

Описание и принцип работы:

Данный тип атак эксплуатирует уязвимости в поддержке фрагментации пакетов протокола IP. Одна из атак этого типа — это пересечение IP-фрагментов. Она реализуется с помощью уязвимости операционной системы, которая заключается в сборке фрагментированных IP- пакетов. В процессе

сборки образуется цикл по принятым фрагментам. Затем из них копируется информативная часть и передаётся на IP уровень. Разработчики предусмотрели проверку на чрезмерный объем копируемой информации, но не ввели проверку на копирование фрагмента отрицательной длины. Копирование блока информации отрицательной длины равносильно копированию очень большого блока информации. Это приводит к затиранию большого участка памяти и к нарушению работы ЭВМ (электронная вычислительная машина). Существует две программы с небольшими отличиями в константах механизма, который осуществляет пересечение IP-фрагментов: newtear и teardrop. Они отправляют пакеты с заданного IP-адреса на любой порт, независимо, открыт он или закрыт. Еще один вариант данной атаки - bonk. После сборки фрагментов в пакете остаются пустые места. Это приводит к сбою ядра операционной системы и нарушению работы электронных вычислительных средств. Данные уязвимости присутствуют в старых версиях ОС (операционных систем) Windows и Linux. На сегодняшний день большинство сетевых ОС защищены от сбоев в работе, вызванных данной атакой.

13. Неверные значения в заголовках пакетов

Уровень атаки: прикладной уровень (L7).

Описание и принцип работы:

Данные атаки нацелены на определённые приложения и операционные системы, которые неправильно обрабатывают некорректные значения в заголовках пакетов. Пример такой атаки — Land attack. В ходе неё злоумышленник устанавливает в пакете одинаковый IP-адрес для источника и приёмника. Это приводит к закликиванию установки соединения сервера с самим собой.

14. Amplification атаки

Уровень атаки: канальный уровень (L2).

Описание и принцип работы:

В основе данных атак лежит отсутствие проверки отправителя в UDP протоколе. Ответ посылается адресату, указанному в заголовках пакета. Злоумышленник может подменить свой IP-адрес на IP-адрес атакуемого сервера в заголовках отправляемых пакетов. Также суть атаки заключается в многократном превышении объёма ответа по сравнению с запросом. Таким образом, злоумышленник может анонимно организовывать атаки с огромным объёмом трафика. Службы, работающие по UDP протоколу: DNS, NTP, SNMP, rsyslog и многие другие, могут использоваться для реализации атаки. Дело в том, что сетевые устройства с этими службами встречаются в сети повсеместно. Службы включены по умолчанию и часто некорректно настроены.

В таблице 1 представлены типы amplification атак, проведённых в ходе исследования. В ней отображается по какому протоколу осуществляются атаки, коэффициент их усиления и уязвимая команда, используемая для реализации атаки.

Таблица 1 — Amplification атаки

Протокол	Коэффициент усиления	Уязвимая команда
DNS	x28-x92	DNS server request
NTP	x994	Monlist request
SNMPv2	x29	GetBulk request
CharGEN	x350	Character generation request
BitTorrent	x4	File search
RIPv1	x131	Malformed request
SSDP	x31	SEARCH request
NetBIOS	x4	Name resolution
Quake Network Protocol	x64	Server info exchange
Steam Protocol	x5.5	Server info exchange

DNS, NTP, SNMPv2 — протоколы для получения информации о доменах, синхронизации времени и сетевого управления. Часто встречаются в сети. NetBIOS и SSDP — протоколы в Windows. CharGEN — старый тестовый сервис, но его до сих пор можно встретить на различных системах. BitTorrent — протокол для обмена файлами. Quake Network Protocol и Steam Protocol — протоколы компьютерных игр.

15.NTP amplification атака

Уровень атаки: канальный уровень (L2).

Описание и принцип работы:

Злоумышленник отправляет запрос monlist с IP-адресом атакуемого сервера к NTP-серверу. Ответ monlist включает в себя список 600 последних клиентов ntpd. Сущность амплификации заключается в том, что нарушитель отправляет небольшой запрос к уязвимому серверу и с него на атакуемый сервер отправляется большой поток UDP трафика. Уязвимый NTP-сервер является невольным промежуточным звеном атаки. Ntpd до версии 4.2.7p26 подвержены атаке.

16.DNS Amplification атака

Уровень атаки: канальный уровень (L2).

Описание и принцип работы:

Атака основана на том, что нарушитель отправляет запрос уязвимому DNS-серверу с IP-адресом атакуемого сервера. DNS-сервер отправляет ответ, размер которого во много раз превышает запрос, жертве. Таким образом, исчерпывается канальная ёмкость атакуемого сервера.

Можно выделить ключевые моменты атаки:

1. Эффект отражения: подмена IP-адреса позволяет перенаправить ответы от всех DNS-серверов на атакуемый сервер.
2. Коэффициент усиления атаки: (amplification factor): он может принимать значения от 28 до 92. То есть на 1 байт запроса — совокупность

DNS-серверов отправит 28-92 байт ответа. Это обеспечивает кратное увеличение объёма трафика.

3. Проблема «open resolver»: это неправильно настроенный или старой версии DNS-сервер. Он разрешает получать запросы из сторонних сетей, выполняя рекурсивные запросы для них, и отправлять ответы без необходимых предварительных проверок.

17.HTTP flood с помощью сервисов

Уровень атаки: прикладной уровень (L7).

Описание и принцип работы:

WordPress сайт с включенным Pingback, можно использовать для проведения HTTP flood атаки на другие сайты. Они отправляют множество запросов к атакуемому сайту со случайными параметрами («?a=a» и др.), с помощью которых обходится кэширование страницы. Эта операция быстро расходует ресурсы атакуемого сервера и нарушает его работу. Злоумышленник может использовать большое количество обычных WordPress сайтов для DDoS атаки и не бояться быть обнаруженным с помощью Pingback запросу к файлу XML-RPC. Google использует FeedFetcher для кэширования любого контента в Google Spreadsheet, вставленного через формулу =image(«link»). Если в клетку таблицы вставить формулу =image(«http://target/file.pdf»), то Google отправит FeedFetcher скачать этот PDF файл и закэшировать для дальнейшего отображения в таблице. Но если добавлять случайный параметр к URL картинке (от «?r=1» до «?r=1000»), FeedFetcher будет скачивать её каждый раз заново. Это приведёт к исчерпанию лимита трафика атакуемого сервера. Злоумышленник может запустить массированную HTTP GET flood атаку на веб-сервер, используя браузер с одной открытой вкладкой.

Задание к практической работе

Для эффективной защиты от распределённых сетевых атак типа «отказ в обслуживании» требуется своевременное обнаружение начала атаки. Чтобы обнаружить DDoS-атаку необходимо накапливать статистические данные о трафике сервера в сети, работающем в штатном режиме. При знании среднестатистических значений характеристик сервера, можно отследить появление аномалии трафика в сети.

Для выполнения данной практической работы необходимо создать две виртуальные машины или объединить в локальную сеть два компьютера. Одна машина будет жертвой, другая злоумышленником.

На машине жертве необходимо установить:

- Web-сервер (Apache, NGINX);
- Средства мониторинга и анализа ресурсов сервера и сетевого трафика (iptraf, ksysguard или другие);

Примечание!!!

Дополнительно ознакомьтесь со следующими ресурсами:

<https://nginx.org/ru/>

<https://httpd.apache.org/>

https://help.ubuntu.ru/wiki/мониторинг_трафика

На машине злоумышленника необходимо установить:

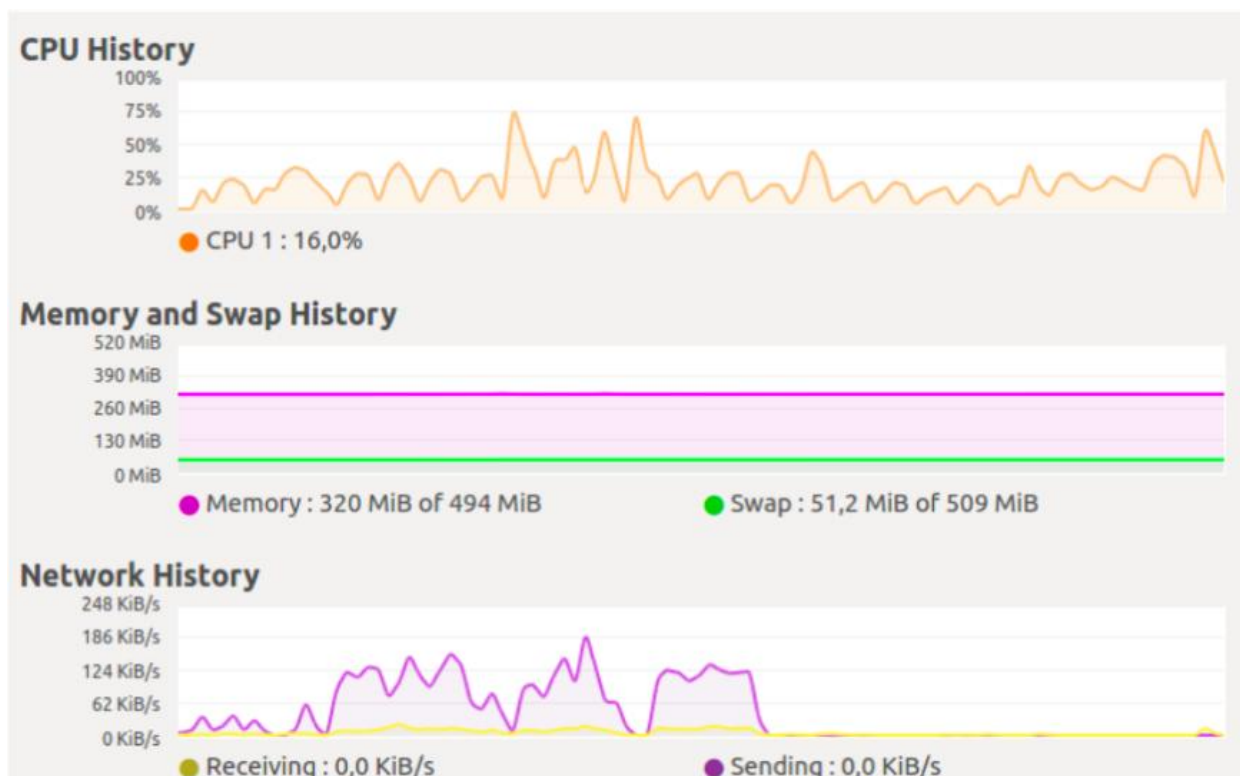
- Программное обеспечение и скрипты для проведения DDoS атак;
- Уязвимые сервисы для усиления DDoS атак (dns, ntp, chargen);

Примечание!!!

Чтобы сделать сервис уязвимым, ознакомьтесь со следующим ресурсом:

<https://habr.com/ru/articles/209438/>

На машине-жертве фиксируются системные характеристики, такие как: загрузки процессора, объем оперативной памяти и характеристики сетевого трафика, такие как: количество пакетов, открытые соединения.



IPTraf							
Proto/Port	Pkts	Bytes	PktsTo	BytesTo	PktsFrom	BytesFrom	
TCP/443	11160	8170815	4543	440587	6617	7730228	
UDP/53	1268	164284	650	45740	618	118544	
UDP/123	8	608	8	608	8	608	
TCP/80	1941	1168863	989	76369	952	1092494	
UDP/68	4	1808	2	1152	2	656	
UDP/67	4	1808	2	656	2	1152	

Скриншоты мониторинга и трафика

Примечание!!!

Изменение указанных характеристик не обязательно обозначает атаку на сервер, но показывает отклонение от среднестатистических показателей работы в штатном режиме. Для большинства DDoS-атак можно выделить аномалии и признаки, соответствующие только им.

В ходе данной практической работы необходимо провести каждый из представленных типов DDoS атак, отследить аномалии в использовании ресурсов сервера и сетевом трафике, проверить признаки DDoS атаки и, если они подтвердились, защитить сервер от атаки с помощью настройки сервера, добавление правил для межсетевого экрана, фильтрации пакетов по сигнатурам.

Пошаговый алгоритм методики:

1. Обнаружение аномалии в наблюдаемых системных характеристиках и характеристиках сетевого трафика.
2. Проверить присутствие признаков атаки в трафике.
3. Внести изменения в настройки сервера под конкретную атаку и внести правила для фильтрации.

Для каждого типа атак в сети интернет необходимо найти по несколько программ и скриптов, которые реализуют данный вид атаки.

- Для атаки HTTP flood: goldeneye, ddosim, DAVOSET, HULK, LOIC, BBH.
- Для медленных атак: r-u-dead-yet, slowhttpstest, pyloris, sockstress, torshammer. Для UDP flood: LOIC, fudp, hping3.
- Для SYN flood и атак на TCP-стек: sprut, sitekiller, mummy, hping3.
- Для ICMP flood: hping3.
- Для land атаки: fudp, hping3.
- Для атак с использованием SSL: thc-ssl-dos.
- Для amplification атак: saddam, chargin_amp.

Примечание!!!

Набор программного обеспечения расположен в папке с практическим заданием!!!

Предупреждение!!!

Ознакомьтесь со справочной документацией используемых Вами программ и скриптов.

Дополнительная информация

Медленные атаки

Аномалия: Кратковременный скачок нагрузки процессора, повышение исходящего трафика и используемой оперативной памяти.

Признак: В TCP-стеке большое количество соединений со статусом ESTABLISHED.

Защита: если установлен apache, то поставить перед ним кэширующий сервер NGINX. Установить и настроить балансировщик нагрузки. На apache можно установить mod_security — firewall с готовыми правилами от OWASP и mod_reqtimeout — установка таймаутов и минимальной скорости передачи данных для получения запросов.

Добавить правила межсетевого экрана:

- ограничение количества соединений с одного IP-адреса;

```
# iptables -A INPUT -p tcp --syn --dport 80 -m connlimit --connlimit-above 30 -j DROP
```

- заблокировать IP после 10 подключений к порту 80 в течение 30 секунд;

```
# iptables -I INPUT -p tcp --dport 80 -m state --state NEW -m recent --set
```

```
# iptables -I INPUT -p tcp --dport 80 -m state --state NEW -m recent --update --seconds 30 --hitcount 10 -j DROP
```

Также NGINX имеет функцию кэширования клиентского запроса перед отправкой на бэкэнд — client_body_buffer_size. Бэкэнд получит запрос, только когда он полностью загрузится.

Атака произвольными пакетами.

Аномалия: Резкое увеличение нагрузки процессора, входящего и исходящего-HTTP трафика.

Признак: на сервер приходит много однотипных пакетов, резко выросло количество обращений к ресурсоёмкому элементу сайта.

Защита: Борьба с HTTP flood ведётся с помощью усовершенствования работы веб-сервера и баз данных. Также меры включают в себя использование обработки подключений методом epoll, увеличение количества соединений, отключение тайм-аута на закрытие подключений keep-alive.

```
worker_processes 2; worker_rlimit_nofile 8000; events {  
    worker_connections 4000;  
    use epoll; }
```

Установить на NGINX модуль ngx_http_limit_req_module и блокировать IP-адреса, которые стали получать ответ «Service unavailable».

```
http {  
    limit_req_zone $binary_remote_addr zone=zne:15m rate=3r/s; server {  
        location / {  
            limit_req zone=zne burst=5;  
        }  
    }
```

Атака произвольными пакетами. UDP-Flood

Аномалия: Резкое увеличение нагрузки процессора, входящего UDP-трафика.

Признак: со всех открытых UDP-портов идёт исходящий трафик.

Защита: необходимо выставить ограничение на количество подключений к открытым портам и закрыть неиспользуемые порты с помощью межсетевых экранов.

Добавить правила межсетевого экрана:

- ограничить количество подключений;

```
# iptables -I INPUT -p udp --dport 53 -j DROP -m iplimit --iplimit-above 1  
# iptables -A OUTPUT -p udp --dport 53 -d 8.8.4.4 -j ACCEPT
```

- блокировать все остальные порты.

```
# iptables -A OUTPUT -p udp -j DROP
```

Атака произвольными пакетами. SYN-Flood

Аномалия: Кратковременный скачок используемых ресурсов процессора и многократное увеличение входящего и исходящего трафика, и их количество равно.

Признак: В TCP-стеке появляется большое количество полуоткрытых соединений со статусом SYN_RECV.

Защита: Современные реализации TCP протокола и некоторые межсетевые экраны имеют механизм защиты от SYN flood атак.

Принцип его действия заключается в следующем:

1. Серверу отправляется запрос на установление соединения, механизм регистрирует его в таблице.
2. После ответа сервера о подтверждении запроса на соединение механизм отправляет пакет серверу с подтверждением соединения и отправляет ответный пакет клиенту. В этот момент в механизме запускается таймер, отсчитывающий время на ответ от клиента.
3. При получении пакета с подтверждением соединения механизм считает запрос валидным, остановит таймер и отправит его на сервер.
4. Если пакет не пришёл в установленное время, механизм отправляет серверу запрос на удаление информации о соединении.

Принцип действие механизма основан на контроле времени задержки ответа клиента. При слишком коротком тайм-ауте будут обрываться легитимные пользователи, при длинном будут накапливаться соединения, что может привести к серьёзным последствиям.

Также можно использовать SYN cookie, или ограничить количество запросов на новые подключения от конкретного пользователя за конкретный период времени. На Рисунке 1 представлен пример настройки ядра операционной системы для защиты от SYN-Flood с помощью команды sysctl.

```
test@test:~$ sudo sysctl -w net.ipv4.tcp_syncookies=1
net.ipv4.tcp_syncookies = 1
test@test:~$ sudo sysctl -w net.ipv4.tcp_max_syn_backlog=4096
net.ipv4.tcp_max_syn_backlog = 4096
test@test:~$ sudo sysctl -w net.ipv4.tcp_keepalive_intvl=10
net.ipv4.tcp_keepalive_intvl = 10
test@test:~$ sudo sysctl -w net.ipv4.tcp_keepalive_probes=5
net.ipv4.tcp_keepalive_probes = 5
test@test:~$ sudo sysctl -w net.ipv4.conf.default.rp_filter=1
net.ipv4.conf.default.rp_filter = 1
test@test:~$ sudo sysctl -w net.ipv4.tcp_synack_retries=1
net.ipv4.tcp_synack_retries = 1
test@test:~$ sudo sysctl -w net.ipv4.tcp_fin_timeout=10
net.ipv4.tcp_fin_timeout = 10
```

Рисунок 1 - настройки ядра операционной системы для защиты от SYN-Flood с помощью команды sysctl.

Атака произвольными пакетами. ICMP-Flood

Аномалия: очень сильная загрузка процессора и сильное увеличение входящего и исходящего ICMP трафика, равного по значениям.

**** Признак: **** Множество пакетов передаётся по протоколу ICMP.

Защита:

Для противодействия атаке возможны следующие меры:

- отключить ответы на ICMP-запросы;

```
#sysctl net.ipv4.icmp_echo_ignore_all=1
```

- понизить приоритет обработки ICMP-сообщений;
- отбросить или фильтровать ICMP-трафик межсетевым экраном;

```
# iptables -A INPUT -p icmp -j DROP --icmp-type 8
```

- увеличить очередь обрабатываемых подключений.

Атака с помощью SSL

Аномалия: Резкое повышение используемых системных ресурсов.

Признак: появляется HTTPS трафик. Большое количество обращений к SSL серверу.

Защита: можно установить правила разрыва соединения с пользователем, выполняющего функцию повторного подтверждения больше заданного количества раз в определённый период времени. Можно использовать контроллер доставки приложений (ADC), чтобы выгрузить SSL с сервера и использовать Web Application Firewall (WAF), для просмотра трафика на наличие атак. Но грамотно спланированные атаки могут превысить количество подключений к этим устройствам и нарушить их работу. Необходимо проводить поведенческий анализ. Целью этих методов является снижение объема трафика атаки пока ресурсы сервера не смогут эффективно бороться с ним. Данный тип атак не отличается поведением от легитимного трафика на сетевом уровне. Из-за этого борьба не всегда эффективна и механизмы ослабления склонны к ложным срабатываниям.

Amplification атаки

Аномалия: Огромное увеличение входящего трафика, которое может достигать до 600 Гб/с.

Признак: Увеличение входящих UDP-пакетов на порты, используемые уязвимыми сервисами. Например, NTP 123 порт, DNS 53 порт, CharGEN 19 порт.

Защита: Такие атаки фильтруются по порту источника и сигнатурам пакетов, так как для каждой amplification атаки используется определённая уязвимая команда сервиса, сигнатура которой известна.

В межсетевом экране необходимо добавить правила:

- закрыть неиспользуемые UDP порты;

```
# iptables -A INPUT -p udp -j DROP
```

- разрешить подключение к X UDP порту только с IP-адреса используемого сервиса;

```
#iptables -A INPUT -p udp --dport X -d x.x.x.x -j ACCEPT
```

– пропускать только пакеты, которые имеют определённую сигнатуру 0x00=0x00000000.

```
# iptables -A INPUT -p udp --dport X -m u32 --u32 «0x00=0x00000000» -j ACCEPT
```

Задания к практической работе:

1. Установить необходимое ПО и настроить сервера.
2. Сделать скриншоты мониторинга ресурсов сервера и сетевого трафика в штатном режиме.
3. Провести несколько атак из списка.
4. Сделать скриншоты мониторинга для каждой проведённой атаки.
5. Написать какие аномалии вы наблюдали в используемых ресурсах сервера, характеристиках сервера, и что является признаком атаки.
6. Защитить сервер от атак и сделать скриншоты результатов.
7. Оформить отчёт по проделанной работе.

Составьте отчет о выполнении практической работы.

Включите в него копии экрана пошагового выполнения задания и ответы на вопросы практической работы.